

CRAFT Configuration and Validation

Certificate Request Agent for Tickets | Administrator Reference

Choose a home-only deployment for an existing user certificate, or configure enrollment as a fallback. Both paths use administrator-controlled trust and ticket policy. Home mode runs certificate loading, validation, PKINIT and cache publication as the caller; only enrollment needs setuid and the service account.



Figure 1. A supplied home pair takes priority; both workflows publish a caller-owned cache.

Home Certificate Installation

From the built source directory, install ordinary root-controlled executables and the public configuration directory. Host provisioning is an administrator task; users then run craft without sudo or special service-account membership.

```

sudo install -d -o root -g root -m 0755 \
  /usr/local/bin /usr/local/libexec /etc/craft
sudo install -o root -g root -m 0755 build/craft /usr/local/bin/craft
sudo install -o root -g root -m 0755 \
  build/craft-worker /usr/local/libexec/craft-worker

```

Use root-owned mode-0644 /etc/craft/config and krb5.conf plus ca-trust.pem, ca-crls.pem, kdc-trust.pem and kdc-crls.pem. Pin the actual KDC, hostname, trusted issuers and current CRLs. Files/parents must be root-controlled, not group/world-writable and not symlinks. Home-only config needs:

```

enabled=yes
domain=domain.local
realm=DOMAIN.LOCAL

```

No agent, service account, keytab, LDAP, CES or /run/craft is required. If enrollment is also configured, keep agent and transport keys/keytabs root:craft mode 0640 and restrict the setuid launcher to approved craft-users. See source/README.md for the full enrollment installation.

Supply the Home Pair

```

mkdir -p ~/.config/craft
chmod 0700 ~/.config/craft
install -m 0600 /path/to/certificate.pem ~/.config/craft/user.pem
install -m 0600 /path/to/private-key.pem ~/.config/craft/user.key

```

Both PEM files must be caller-owned, regular, nonempty and at most 1 MiB each, without symlinks or extra hard links. The key must be unencrypted and private; directories must not be group/world-writable. HOME and XDG overrides do not change the NSS location. Direct PFX, passphrase prompts, PKCS#11 and HSM backends are unsupported.

Home certificates need a matching key, explicit CA:FALSE without path length, digitalSignature without signing usage, Smart Card Logon or PKINIT Client Authentication EKU, exactly one well-formed UPN SAN, current validity, trusted chain and current CRLs. Ordinary validity periods and other templates are accepted. The KDC maps the certificate to the fixed Linux-name principal; no LDAP UPN comparison occurs.

A complete pair takes priority. Partial, unsafe, encrypted, malformed, expired or revoked inputs fail and retain the cache. Remove both files deliberately to select enrollment. CRAFT leaves supplied files in place; users replace them before expiry. A non-setuid home-only installation reports the enrollment prerequisite when no pair exists.

Enrollment Configuration

Enrollment User Certificate Template

This profile applies to certificates enrolled by CRAFT. The CA controls issuance; CSR extensions are requests. The CA supplies the SID for domain-controller mapping, and enrollment requires all three client EKUs below. Home mode uses its separate login profile and does not pin this template or ten-hour certificate cap. [1, 2, 6]

Property	Enrollment Profile Required by CRAFT
Subject and identity	Requested CN is configurable. UPN otherName 1.3.6.1.4.1.311.20.2.3 must match the directory-resolved UPN.
Client EKUs	Client Authentication: 1.3.6.1.5.5.7.3.2 Smart Card Logon: 1.3.6.1.4.1.311.20.2.2 PKINIT Client Authentication: 1.3.6.1.5.2.3.4
Key and basic constraints	RSA-3072; explicit CA:FALSE, no path length. digitalSignature required; keyCertSign/cRLSign forbidden. CSR also requests keyEncipherment.
Certificate template	Template OID must match configuration.
Validity and trust	Default cap: ten hours TOTAL, including backdating. Require matching key, valid chain and current CRLs.
Agent / DC profiles	Agent: Certificate Request Agent ECU 1.3.6.1.4.1.311.20.2.1. DC: a valid PKINIT KDC certificate and configured KDC trust/hostname checks.

Enrollment Settings and Shared Ticket Policy

```
certificate_cn={user}
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
cert_remaining_max_seconds=36000
cert_total_max_seconds=36000
```

certificate_cn and the certificate caps apply only to enrollment. CN tokens are {user}, directory-resolved {upn} and {domain}; the result must be 1-64 printable ASCII characters. The CA may replace it. tgt_seconds, renew_seconds and require_full_tgt_lifetime apply to both workflows; a longer home certificate does not lengthen their ticket requests.

Enrollment with either CES mode requires service_principal and submitter.keytab for LDAP/GSSAPI. Pin the GC host/search base and manage local/AD account names centrally. Home mode needs no directory credentials or lookup; the KDC maps the supplied certificate to <Linux username>@<realm>.

Build and Validate in a Lab

Preparation	Required Action
Linux build	C++20 with std::format; OpenSSL 3, MIT Kerberos, curl, libxml2, OpenLDAP and SASL build libraries. MIT PKINIT at runtime; SASL GSSAPI additionally for enrollment. See source/README.md.
Enrollment preparation	For enrollment only: restrict the agent, template and recipients; CES allows initial enrollment via Negotiate or mTLS. Both need the directory keytab; mTLS also needs a client certificate. [3]
DC policy and AES	Policy must permit a 10-hour initial TGT and 7-day renewal window; PKINIT can limit the initial grant by certificate expiry. Require AES256/AES128 for user and transport tickets. [1, 4, 7]
Installation boundary	Home-only: ordinary launcher/worker with readable root-controlled public config and trust. Enrollment: add the setuid craft launcher, craft service account, craft-users and private keys/keytabs. Maintainer remains unprivileged.

```
cmake -S source -B build -DCMAKE_BUILD_TYPE=Release
cmake --build build -j2
ctest --test-dir build --output-on-failure
```

Acceptance Checks

Home mode: validate ordinary non-setuid execution with no enrollment credentials. Confirm the supplied pair takes priority, no directory/CES/rate-limit access occurs, and inherited no_new_privs works. Test partial/unsafe pairs, revocation, certificate replacement and a valid certificate for another KDC account; failures must preserve the cache.

Enrollment: verify directory UPN lookup, agent/recipient restrictions and CA audit identity. Inspect issued UPN, template, key, three EKUs, CN behavior, chain, CRLs and total validity; confirm CA SID issuance and DC mapping.

Both workflows: invoke craft directly as the intended non-root user. Inspect caller-owned cache mode, returned Linux-name principal, TGT times, renewable/nonforwardable/nonproxiable flags and AES session/ticket encryption with klist -ef.

```
if cache=$(/usr/local/bin/craft); then
    export KRB5CCNAME="$cache"
    klist -ef -c "$KRB5CCNAME"
fi
```

Failure checks: preserve the existing cache for shortened strict-mode grants, unsafe homes, wrong mapping or keys, missing logon usage, revoked certificates, stale CRLs, RC4 and KDC failure. Home mode must not enroll after partial or invalid inputs. Enrollment also rejects wrong directory UPN/template and excessive certificate validity.

Test a real AD application and maintenance under the actual scheduler. Review AUTHPRIV/KDC logs and CA/CES logs for enrollment. Define supplied-pair replacement, credential rotation, CRL refresh, account lifecycle, cache protection and incident response.

Offline fixtures remain synthetic. Installed home-mode PKINIT, service-ticket and failure checks passed against a disposable MIT KDC; this does not establish AD mapping or CES interoperability. Run current checks and complete the appropriate source/TESTING.md acceptance cases in your lab.

Long Running Jobs

After building, install the maintainer as an ordinary executable alongside the launcher:

```
sudo install -o root -g root -m 0755 \
  build/craft-maintain /usr/local/bin/craft-maintain
```

Requires Linux 5.3+, /proc and system /etc/krb5.conf matching the configured realm/KDC and AES policy. Public /etc/craft configuration and trust remain root-controlled and readable; enrollment keys/keytabs remain private. Home-only refresh works under no_new_privs. Enrollment fallback requires later setuid craft calls; the scheduler must retain background processes.

Start once as the batch user. Watch its shell or persistent job controller; exec preserves the shell PID.

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

Renewal uses the cache alone. Fresh authentication occurs near the renewal deadline and invokes craft with home-pair priority: reuse a valid pair, or enroll when both files are absent. Ten-hour/seven-day grants normally renew at eight hours and refresh around day six. Optional --max-duration 21d adds a cutoff; concurrent jobs share cache updates and fresh-acquisition backoff.

```
/usr/local/bin/craft-maintain --status --watch-pid "$job_pid"
klist -ef -c "$KRB5CCNAME"
```

Status reports ready/retrying/expired/stopped/failed, Unix ticket times and errors; a successful read does not prove credential health. Status files and the shared cache remain after exit. Refresh failures preserve cached credentials and retry; later failures do not stop the job.

Test renewal, rollover, certificate replacement, outages, reconnects and concurrent jobs under the actual scheduler. Renewal can outlast certificate expiry; fresh PKINIT needs a valid pair or authorized enrollment. Confirm maintenance stops with its watched PID. Keep CRLs and the selected credentials current; CRAFT does not renew or delete supplied home certificates.

Primary References

- [1] [RFC 4556, sections 3.2.2–3.2.3: client certificate usage and ticket/key lifetime](#)
- [2] [Microsoft MS-WCCE: CA certificate SID security extension](#)
- [3] [Microsoft: Configure Certificate Enrollment Web Service](#)
- [4] [MIT Kerberos: encryption types, ticket lifetime and KDC options](#)
- [5] [MIT Kerberos: PKINIT configuration and Active Directory considerations](#)
- [6] [Microsoft KB5014754: strong certificate-to-account mapping](#)
- [7] [Microsoft: Maximum lifetime for user ticket \(hours\)](#)

Source implementation and test suite: see [source/](#) in the repository.

License

CRAFT source code, scripts, configuration examples, and documentation are licensed under the GNU General Public License, version 3 (SPDX: GPL-3.0-only). See the repository LICENSE file or <https://www.gnu.org/licenses/gpl-3.0.html> for the full terms. This material is provided without warranty, as described in the license.